
DIGITAL FORENSICS & INCIDENT RESPONSE

Date: 5/05/2026

Submitted by Arya Sharma

TABLE OF CONTENTS

#	Topic	Page
1	Digital Forensics in Incident Response (DFIR)	3
2	Advanced Disk & Memory Forensics	5
3	Malware Analysis for Incident Responders	8
4	Incident Response Lifecycle (NIST SP 800-61)	11
5	Post-Incident Analysis & Executive Reporting	14
—	Quick Reference: Key Tools Summary	17
—	Quick Reference: MITRE ATT&CK Techniques Used	17

Topic 1: Digital Forensics in Incident Response (DFIR)

1.1 What is Digital Forensics?

Digital Forensics is the science of collecting, preserving, analyzing, and presenting digital evidence in a way that is legally and technically sound. It is the process of answering the question: WHAT happened on this computer or network?

Think of a digital forensics' analyst as a detective. Just like a detective at a physical crime scene collects fingerprints, footprints, and CCTV footage — a digital forensics analyst collects RAM dumps, log files, disk images, and network captures.

KEY POINT

Digital evidence is fragile. It can be overwritten, modified, or lost in seconds. A forensics analyst's first priority is always to PRESERVE evidence before examining it.

1.2 What is Incident Response (IR)?

Incident Response is the structured process an organization follows when a cybersecurity attack or breach occurs. Its goals are:

- Detect the attack as early as possible
- Contain the damage so it does not spread
- Eradicate the attacker and all their tools from the environment
- Recover systems back to normal operations
- Learn from the incident to prevent it from happening again

1.3 What is DFIR? — The Combination

DFIR combines both disciplines. During a live incident, you cannot just wait and analyze slowly — the attacker is still active, data is being stolen, and evidence is disappearing every second. DFIR is the practice of doing forensics WHILE responding to an active incident.

KEY POINT

One sentence summary: DFIR = Using forensics evidence to make better, faster, and more accurate incident response decisions.

1.4 DFIR vs. Traditional (Lab) Forensics

Aspect	Traditional Lab Forensics	DFIR (Active Incident)
Timing	System is already OFF no active attacker	System is still ON attacker may be present right now
Speed	Take your time — weeks if needed	Minutes to hours — urgency is critical
Primary Goal	Complete, perfect evidence for court	Stop the attack first, preserve evidence where possible
System State	Everything is static — nothing changes	Everything is dynamic — processes run, logs roll, RAM changes
Main Risk	Missing evidence from poor technique	Losing volatile evidence or alerting attacker to your presence
Tools	Autopsy, FTK, EnCase (lab-grade)	Velociraptor, WinPmem, Volatility (live tools)
Documentation	Detailed chain of custody for court	Quick documentation + chain of custody simultaneously

1.5 The Golden Rule: Evidence Collection Order (RFC 3227)

RFC 3227 is an internationally recognized standard published in 2000 that defines the correct ORDER in which to collect digital evidence. The rule is simple and absolute: ALWAYS collect the most volatile evidence first.

CRITICAL RULE

NEVER turn off a live machine during an active incident! If you power it off, you permanently lose ALL RAM contents — including running malware, active network connections, passwords, and encryption keys.

Order	Evidence Type	Why It Disappears	Examples	Tool to Use
1st (Most Volatile)	CPU Registers & Cache	Gone the instant power is cut	Currently executing instructions	Not practically collectible — collect RAM instead
2nd	RAM / Memory	Lost completely on reboot	Running malware, passwords, encryption keys, opened files	WinPmem, Volatility, Velociraptor
3rd	Active Network Connections	Drop within seconds/minutes	Who is connected to C2 right now, open sessions	netstat, Wireshark, Velociraptor
4th	Running Processes	Disappear after reboot	Malware process that has no file on disk (fileless malware)	tasklist, Velociraptor, Volatility pslist
5th	Open Files & File Handles	Close on restart	Files the attacker is actively reading or writing	Velociraptor, handle.exe (Sysinternals)
6th	Disk Image	Survives power-off indefinitely	All installed files, logs, registry, deleted file remnants	FTK Imager, dd, dcfldd

7th	Remote / System Logs	Stable — backed up elsewhere	SIEM events, firewall logs, email logs	SIEM export, syslog collection
8th (Least Volatile)	Archived Media / Backups	Most stable — rarely changes	Offline backups, cold storage	Standard file copy with hash verification

1.6 Live Forensics — Working on a Running System

Live forensics means collecting evidence from a machine that is **STILL RUNNING** and **STILL CONNECTED** (or just about to be disconnected). This is the normal situation at the start of a DFIR investigation.

Velociraptor — Remote Live Forensics Tool

Velociraptor is a powerful open-source endpoint forensics platform. It works like this: a lightweight agent is installed on endpoints in your environment. When you need to investigate, you connect from the Velociraptor server and run queries on the live endpoint remotely — without touching the physical machine.

- You can query running processes: `SELECT pid, name, path, cmdline FROM processes`
- You can query network connections: `SELECT * FROM netstat`
- You can collect artifacts: prefetch files, registry hives, event logs — all without touching the machine
- You can deploy it remotely to thousands of endpoints at once — perfect for large-scale incident scoping

WinPmem — Memory Acquisition Tool

WinPmem creates a complete dump of RAM (a snapshot of everything currently in memory) from a live Windows system. The output file is the same size as the RAM in the machine (e.g., 16 GB RAM = 16 GB dump file).

```
winpmem_mini_x64.exe C:\evidence\memory_dump.raw
-- Wait for completion (5-20 minutes depending on RAM size)
-- Then compute hash: certutil -hashfile memory_dump.raw SHA256
```

FTK Imager — Forensic Disk Imaging Tool

FTK Imager creates a forensic disk image — an exact bit-for-bit copy of a hard drive including every file, deleted file, free space, and metadata. The image is saved in .E01 format (EnCase Evidence File) which includes automatic hash verification.

KEY POINT

A forensic image is **NOT** the same as a regular backup or file copy. It captures **EVERYTHING** on the drive including deleted files, slack space, and the unallocated areas — things a regular copy would miss.

1.7 Hash Verification — Proving Evidence Integrity

After collecting any evidence file, you **MUST** compute a SHA-256 cryptographic hash of the file. This hash is a unique 'fingerprint' of the file. If even one byte of the file changes, the hash changes completely. This proves your evidence has not been tampered with.

```
Windows: certutil -hashfile evidence_file.E01 SHA256
Linux: sha256sum evidence_file.E01
```

Record the hash and store it separately from the evidence.
When you analyze the evidence, re-verify the hash first.

Hash Status	What it Means	Action Required
Hashes match (original = copy)	Evidence is intact not modified since collection	Proceed with analysis evidence is valid
Hashes do NOT match	Evidence may have been corrupted or tampered with	DO NOT use in legal proceedings investigate the discrepancy
No hash was collected	Evidence integrity cannot be proven	Evidence is significantly weakened document why hash was not taken

1.8 Artifact Correlation Building the Full Picture

The most powerful DFIR skill is not any single tool it is the ability to **CORRELATE** (connect) evidence from multiple sources to tell a complete story. A single artifact alone is rarely conclusive. The combination of multiple artifacts from different sources creates a timeline that is nearly impossible to dispute.

Evidence Source	What it Tells You	Alone is...	Combined is...
Disk artifact: svchost32.exe found in AppData\Temp	A suspicious file existed on the system	Suspicious but could be legitimate	Strong evidence confirms attacker presence
Memory: svchost32.exe process (PID 3821) running	This file was actively running at capture time	Suspicious — could be any process	Confirms the file on disk was actively malicious
Network: PID 3821 connected to 203.0.113.88:4444	This process was talking to an external IP	Could be legitimate network tool	CONFIRMED: Active C2 connection from identified malware
Prefetch: SVCHOST32.EXE-XXXX.pf with timestamps	The program ran for the first time at 01:10:00	Just shows it ran	Timeline confirmation: malware ran at 01:10, C2 started at 01:15 — matches perfectly

1.9 Study Resources for Topic 1

Resource	URL	What You Will Learn
RFC 3227 — Evidence Collection Order	https://www.rfc-editor.org/rfc/rfc3227	The official standard for evidence collection order and handling
The DFIR Report	https://thedfirreport.com	Real-world DFIR walkthroughs with complete timelines and TTPs
Velociraptor Documentation	https://docs.velociraptor.app	How to use Velociraptor for live forensics and endpoint queries
WinPmem GitHub	https://github.com/Velocidex/WinPmem	Download WinPmem and learn memory acquisition techniques

Topic 2: Advanced Disk & Memory Forensics

2.1 Disk Forensics — What Stays on the Hard Drive

Even when an attacker deletes their files and tries to hide their tracks, the hard drive remembers. Windows is a remarkably helpful witness because it automatically creates dozens of artifact files recording what programs ran, what files were opened, what USB drives were connected, and much more. Knowing WHERE these artifacts are stored and what they reveal is the core skill of disk forensics.

KEY POINT

Key insight: Attackers almost always leave traces on disk even when they try to clean up. The Windows operating system itself creates many of these traces automatically, and attackers often do not know about all of them.

2.2 The Most Important Windows Forensic Artifacts

Prefetch Files

Property	Details
What it is	A performance optimization file Windows creates when a program runs for the first time
Location	C:\Windows\Prefetch\
File format	APPNAME-XXXXXXXX.pf (e.g., SVCHOST32.EXE-AB1234CD.pf)
What it records	Program name, full path, 1st run time, last 8 run timestamps, run count, DLLs/files accessed
Why it matters	Even if the malware file was deleted, the prefetch file REMAINS and proves it ran
Analysis tool	PECmd.exe (Eric Zimmerman — free download: https://ericzimmerman.github.io)
Forensic goldmine	Timestomping a file does NOT affect the prefetch timestamp — so prefetch timestamps are hard to fake

Master File Table (MFT)

The MFT is the file system's index it contains an entry for EVERY file and folder on an NTFS drive. Each entry contains the file name, size, timestamps (Created, Modified, Accessed, MFT Entry Modified all four!), and data location on disk.

- When a file is deleted, its MFT entry is marked as 'available' but the data often remains on disk until overwritten
- Forensic tools (Autopsy, FTK) can parse the MFT to recover deleted files and their metadata
- The \$MFT file itself is a critical evidence file — always examine it when analyzing a disk image

PRO TIP

The MFT has FOUR timestamps per file (\$STANDARD_INFO and \$FILE_NAME attributes). Timestamping tools usually only change \$STANDARD_INFO. If \$FILE_NAME timestamps differ from \$STANDARD_INFO, the file has been timestamped.

Windows Registry The Configuration Database

The Windows Registry is a hierarchical database that stores configuration settings for Windows and all installed applications. For forensics, it is an absolute goldmine because it records EVERYTHING from what programs were installed, to what USB drives were ever connected, to what files were recently opened.

Registry File	Hive	Location on Disk	What it Contains
SYSTEM		C:\Windows\System32\config\SYSTEM	Services, drivers, device history, USBSTOR history, network interface config
SOFTWARE		C:\Windows\System32\config\SOFTWARE	Installed applications, OS settings, startup programs, Windows version
SAM		C:\Windows\System32\config\SAM	Local user accounts and their password hashes
SECURITY		C:\Windows\System32\config\SECURITY	Security policies, audit settings, cached domain credentials
NTUSER.DAT		C:\Users\[Username]\NTUSER.DAT	Per-user settings: recently opened files, recently run programs, mapped drives
UsrClass.dat		C:\Users\[Username]\AppData\Local\Microsoft\Windows\UsrClass.dat	Shellbags (folder access history), file associations

Critical Registry Keys for DFIR

Registry Key	What it Shows	Why Attackers Use It
HKLM\SOFTWARE\Microsoft\Windows\CurrentVersion\Run	Programs that start when Windows boots (all users)	Most common attacker persistence location easy to add, survives reboot
HKCU\SOFTWARE\Microsoft\Windows\CurrentVersion\Run	Programs that start when THIS user logs in	User-level persistence no admin rights needed
HKLM\SYSTEM\CurrentControlSet\Services	Installed Windows services (including malicious ones)	Attackers create malicious services for persistent, stealthy execution
HKLM\SYSTEM\CurrentControlSet\Enum\USBSTOR	Record of every USB device ever connected (serial number, name, date)	Proves USB was connected — even if USB is now removed
HKCU\...\Explorer\RecentDocs	Files recently opened by the user	Shows attacker accessed specific sensitive files
HKCU\...\Explorer\UserAssist	Programs run via Windows Explorer — ROT13 encoded	Records execution count and last run time for every launched program

HKLM\...\AppCompatCache (Shimcache)	Record of every executable file seen on the system	Even deleted programs leave entries here — proves file existed
HKLM\...\Amcache.hve	Detailed info on recently executed programs (hash, compile time, publisher)	Cannot be easily faked — contains SHA-1 hash of the executable

LNK Files (Windows Shortcut Files)

Windows automatically creates .lnk (shortcut) files whenever a user opens a file through Windows Explorer. These contain rich forensic information and are created automatically the user cannot prevent this.

Location	C:\Users\[Username]\AppData\Roaming\Microsoft\Windows\Recent\
What LNK Contains	Original file path, volume serial number, file size at time of opening, MAC timestamps, machine hostname, MAC address
Forensic Value	If attacker opened C:\Confidential\patient_data.xlsx — a .lnk file PROVES it, even if the .xlsx was later deleted

Jump Lists

Jump Lists show recently and frequently used files per application. They are stored in the user's AppData folder. If an attacker opened a document using Microsoft Word, the file path will appear in Word's Jump List — a very useful artifact even if the document was deleted afterward.

Location	C:\Users\[Username]\AppData\Roaming\Microsoft\Windows\Recent\AutomaticDestinations\
-----------------	---

2.3 File Carving — Recovering Deleted Files

File carving is the process of recovering deleted files from a disk by searching for file header and footer signatures in the raw disk data. When a file is deleted, Windows only removes the directory entry — the actual file data often remains on disk until the storage space is reused.

- JPEG files always start with: FF D8 FF — File carving finds these signatures in unallocated space
- ZIP/RAR files always start with: 50 4B 03 04 — This is how patient_records.zip could be recovered
- PE (Windows .exe) files always start with: 4D 5A (MZ) — Malware can be recovered this way

PRO TIP

Tool: Autopsy has built-in file carving. You can also use PhotoRec (free, cross-platform). These tools find deleted files even without MFT entries.

2.4 Anti-Forensics — How Attackers Try to Hide

Sophisticated attackers know about forensics. They use anti-forensics techniques to destroy, hide, or confuse the evidence trail. As a DFIR analyst, you need to recognize these techniques — because the ATTEMPT to hide evidence is itself evidence.

Technique	What the Attacker Does	How You Detect It	Why It Often Fails
Timestomping	Changes file timestamps (Created, Modified, Accessed) using tools like Timestomp.exe	Compare \$STANDARD_INFO timestamps vs \$FILE_NAME timestamps (both in MFT). If they differ = timestomping. Also compare with prefetch timestamps.	\$FILE_NAME timestamps are harder to change. Prefetch timestamps often contradict faked disk timestamps.
Log Clearing	Deletes Windows Event Logs using wevtutil or Event Viewer	Check for Event ID 1102 (Security log cleared) and Event ID 104 (System log cleared). The CLEARING EVENT itself is logged in the Security log!	Windows logs the clearing event BEFORE deleting the log, so you see evidence of clearing even in cleared logs.
Secure File Deletion	Overwrites file content with zeros/random data before deleting (SDelete, Eraser)	Look for evidence of SDelete/Eraser in Prefetch, look for patterns of zeros in unallocated space	The wiping TOOL itself leaves Prefetch and registry traces, proving the attacker tried to hide something.
Process Injection	Injects malicious code into a LEGITIMATE process so the malicious network connection appears to come from e.g. svchost.exe	Volatility windows.malfind detects RWX memory regions. Compare process executable on disk vs in memory.	Memory still contains the injected code. Volatility can extract it even from 'legitimate' processes.
Fileless Malware	Runs malware entirely in memory — no file is ever written to disk	Look in memory with Volatility. Check PowerShell logs. Check amcache/shimcache for scripts.	Memory dump captures everything. PowerShell logging (if enabled) records the full script.

2.5 Memory Forensics with Volatility 3

Volatility 3 is the world's most widely-used open-source memory forensics framework. It analyzes a raw memory dump and extracts structured information. The key principle: malware cannot hide in memory from Volatility the way it can hide on disk.

KEY POINT

Memory forensics is often the MOST IMPORTANT part of a DFIR investigation because: (1) Fileless malware leaves no disk trace, (2) Memory contains process execution evidence even after the process is killed, (3) Memory contains active network connections, passwords, and encryption keys.

Setting Up Volatility 3

```
# Install
pip install volatility3
```

```
# OR clone from GitHub
git clone https://github.com/volatilityfoundation/volatility3
```

```
cd volatility3 && pip install -e .

# Check memory dump OS info first
python3 vol.py -f memory_dump.raw windows.info
```

Complete Volatility Plugin Reference

Plugin	Full Command	What it Does	What to Look For
windows.pslist	python3 vol.py windows.pslist -f mem.raw	Lists all running processes: PID, parent PID, process name, path, start time, exit time	Unusual names (svchost32 vs svchost), processes running from AppData/Temp/Desktop
windows.pstree	python3 vol.py windows.pstree -f mem.raw	Same as pslist but shows parent-child tree structure	Word.exe > cmd.exe > malware.exe (macro dropper chain!)
windows.netstat	python3 vol.py windows.netstat -f mem.raw	Shows all active and recently closed network connections	Connections to unknown external IPs on non-standard ports
windows.malfind	python3 vol.py windows.malfind -f mem.raw	Finds memory regions with RWX permissions containing PE code or shellcode	MZ header in unexpected memory = injected executable; RWX + high entropy = shellcode
windows.dlllist	python3 vol.py windows.dlllist -f mem.raw	Lists all DLLs loaded by each process	Malicious DLL masquerading as system DLL; DLL loaded from temp folder
windows.cmdline	python3 vol.py windows.cmdline -f mem.raw	Shows command-line arguments used to start each process	Long base64 strings = encoded PowerShell; suspicious flags
windows.filescan	python3 vol.py windows.filescan -f mem.raw	Scans memory for file objects (files open in RAM)	Find malware files that were deleted from disk but are still open in memory
windows.dumpfiles	python3 vol.py windows.dumpfiles --pid [PID] -f mem.raw	Extracts file data from memory to disk for further analysis	Use to recover malware binary that was deleted from disk
windows.hashdump	python3 vol.py windows.hashdump -f mem.raw	Extracts NTLM password hashes from memory	Shows what credentials the attacker may have captured
windows.svcscan	python3 vol.py windows.svcscan -f mem.raw	Lists all Windows services including hidden ones	Malicious services created by the attacker for persistence

Interpreting Volatility Output — Suspicious Indicators

What You See	Why It Is Suspicious	Real Example from Scenario
Process name is a misspelling of a system process	Attackers mimic legitimate names to avoid detection	svchost32.exe — real Windows process is svchost.exe (no '32')
Process running from AppData, Temp, or Desktop	Legitimate Windows processes NEVER run from user folders	C:\Users\finance\AppData\Temp\svchost32.exe
cmd.exe or powershell.exe as child of Office (winword, excel)	Office apps should never spawn command-line tools — indicates macro attack	winword.exe (1234) > cmd.exe (2456) > svchost32.exe (3821)
ESTABLISHED connection to external IP on unusual port	Production workstations have limited legitimate external connections	svchost32.exe > 203.0.113.88:4444 ESTABLISHED
RWX memory region with MZ header (from malfind)	Code injection — attacker injected a PE file into another process's memory	PID 3821: RWX region at 0x00400000, MZ header detected
Process with no parent (PPID points to non-existent PID)	Orphaned process — often seen when parent process was killed after launching malware	svchost32.exe PPID = 0 (parent gone — launched and terminated)

2.6 Study Resources for Topic 2

Resource	URL	What You Will Learn
Volatility 3 GitHub & Plugin Reference	https://github.com/volatilityfoundation/volatility3	All Volatility plugins with documentation and examples
13Cubed YouTube Channel	https://www.youtube.com/@13Cubed	Excellent video walkthroughs of every Windows forensic artifact
CyberDefenders MemLabs	https://cyberdefenders.org/blueteam-ctf-challenges/memlabs	Hands-on memory forensics CTF challenges with real memory dumps
SANS FOR508 Cheat Sheet	Search: SANS FOR508 Windows Forensics Cheat Sheet	Master list of all Windows artifact locations and their forensic value

Topic 3: Malware Analysis for Incident Responders

3.1 The Triage-First Mindset

During a live incident, you do NOT have 3 days to fully reverse-engineer malware. You have 30-60 minutes to extract enough information to:

- Identify the malware family and understand its capabilities (what can it do?)
- Extract IOCs (Indicators of Compromise) — C2 IP, hash, mutex, registry key, domain
- Share IOCs with the team immediately so the rest of the infrastructure can be protected
- Determine if the malware has network capabilities, exfiltration capabilities, or can spread
- Decide on the containment strategy — isolate immediately? Block at network level?

CRITICAL RULE

Triage does NOT mean sloppy. It means focused: answer the most important questions first. Deep reverse engineering comes AFTER containment.

KEY POINT

IOC = Indicator of Compromise. A specific piece of evidence that proves a system has been compromised. Examples: SHA-256 hash of malware file, C2 IP address (203.0.113.88), mutex name ('FinRat_Mutex_v2'), registry key ('HKLM\...\Run\svchost32'), malicious domain. Always share IOCs immediately.

3.2 Static Analysis — Examine Without Running

Static analysis examines the malware file itself WITHOUT executing it. It is completely safe — you cannot get infected by looking at a file. The goal is to extract as much information as possible from the file structure, strings, and metadata alone.

PEStudio — PE File Analyzer

PEStudio (free, Windows) analyzes Windows PE (Portable Executable) files — the format of all .exe, .dll, and .sys files. It automatically highlights hundreds of suspicious indicators in red and yellow.

Tab in PEStudio	What It Shows	What to Look For
Indicators	Auto-detected suspicious properties	Red items = high risk. Common: 'no version info', 'self-modifying', 'creates processes', 'accesses internet'
Imports	Windows API functions the malware uses	CreateRemoteThread (injection), WriteProcessMemory (injection), WinExec/ShellExecute (launches programs), InternetOpen (network), CryptEncrypt (encryption)
Strings	Readable text embedded in the binary	URLs (http://), IP addresses, registry paths, file paths, mutex names, error messages

Sections	PE sections: .text (code), .data (data), .rsrc (resources), UPX0/UPX1 (packed)	High entropy (>7.0) in any section = packed/encrypted malware to bypass AV
Libraries (Imports)	Which DLLs the malware links against	WS2_32.dll (network), WININET.dll (HTTP), CRYPT32.dll (crypto), NTDLL.dll (low-level)
File	Basic file info: size, hash, compile time, linker version	Compile time of 2000-2001 = fake/timestamped. Hash = check on VirusTotal

FLOSS — Obfuscated String Extractor

The regular 'strings' command only finds plain ASCII/Unicode text. Malware authors encode their strings (C2 URLs, registry paths, etc.) to hide them from basic analysis. FLOSS (FLARE Obfuscated String Solver) by Mandiant actually RUNS the decoding routines inside the binary and extracts the decoded strings.

```
floss.exe svchost32.exe > floss_output.txt

# Search the output for:
findstr /i "http ftp tcp 203.0 registry run cmd powershell" floss_output.txt
```

String Type to Find	What It Reveals	Example
C2 URLs	Where malware calls home	http://203.0.113.88/gate.php or hxxp://evil[.]com/check-in
IP Addresses	Direct C2 connections bypassing DNS	203.0.113.88 or 10.0.0.1:4444
Registry Paths	Persistence locations	SOFTWARE\Microsoft\Windows\CurrentVersion\Run\svchost32
Mutex Names	Unique identifier — prevents two copies running	FinRat_Mutex_v2_UNIQUE_ID (perfect for YARA rules!)
File Paths	Where malware drops additional files	C:\Users\%USERNAME%\AppData\Temp\update.exe
Encoded Commands	Obfuscated PowerShell or cmd	cG93ZXJzaGVsbCAtZW5j... (base64-encoded PowerShell)
Error/Debug Strings	Reveal internal malware structure	'[+] C2 connected' or '[!] Injection failed' — developer left debug messages in!

VirusTotal — Hash & File Reputation Check

VirusTotal (<https://www.virustotal.com>) checks your file's hash against 70+ antivirus engines simultaneously AND provides community intelligence about the file.

VirusTotal Section	What to Check	What It Tells You
Detection	Number and names of AV detections	47/72 = highly malicious. 0/72 does NOT mean clean (custom/new malware)
Details	File metadata, compilation time, PE info	Verify file properties match what you see in PEStudio

Relations	Associated IPs, domains, files	Shows the full malware infrastructure — C2 server, download URLs, related samples
Behavior	Sandbox analysis from multiple engines	Automated summary of what the malware does if run
Community	Comments from security researchers	Sometimes contains malware family name, attribution, or specific IOCs

CRITICAL RULE

A 0/72 detection score does NOT mean the file is clean! Customized or freshly compiled malware is often not detected by AV. Always continue with dynamic analysis even if VirusTotal shows clean.

3.3 Dynamic Analysis — Run in a Sandbox

Dynamic analysis means actually executing the malware in a controlled, isolated environment (a sandbox) and watching what it does. The sandbox captures everything: every process started, every file created, every registry key modified, every network connection made.

Tool	Type	Pros	Cons	When to Use
ANY.RUN	Interactive Online Sandbox	Real-time interactive view, instant results, free tier available, easy MITRE ATT&CK mapping	Public — uploaded samples visible to anyone, may tip off sophisticated attackers	For non-sensitive samples, quick triage, when speed matters
Cuckoo Sandbox	Self-hosted Sandbox	Private — samples stay internal, highly customizable, offline capable	Requires setup and maintenance, needs dedicated VM environment	For sensitive/confidential samples, regulated data environments
Hybrid Analysis	Online Sandbox	Free, multiple analysis engines, good MITRE mapping	Public like ANY.RUN	Useful as second opinion alongside ANY.RUN

What to Document from Dynamic Analysis

Activity Category	What to Record	Evidence of in Our Scenario
Process Tree	Every process spawned — parent > child relationships	WINWORD.EXE > CMD.EXE > SVCHOST32.EXE
Network Activity	Every IP, domain, port, protocol, request content	TCP connection to 203.0.113.88:4444 at 60-second intervals
File Activity	Files created, modified, or deleted — with full paths and hashes	Drop of update.exe in Temp, deletion of patient_records.zip after exfil
Registry Activity	All registry keys read, created, or modified	HKLM\...\Run\svchost32 created for persistence
DNS Queries	Every domain name resolved during execution	Unusual subdomains, high-frequency queries to same domain
HTTP Requests	HTTP methods, URLs, User-Agent, POST data size	POST to /gate.php with 38MB body — exfiltration

3.4 C2 Beacons Patterns — How Attackers Stay Connected

After infecting a machine, malware maintains a communication channel back to the attacker. This is called Command and Control (C2). Recognizing C2 beacon patterns in network traffic is essential for detection and containment.

Pattern Type	Description	What it Looks Like	Detection Technique
Fixed Interval Beacon	Malware contacts C2 server every X seconds, exactly	Wireshark shows packets to 203.0.113.88 every 60.0 seconds like clockwork	Look for packets with identical time delta to same external IP; automatable in Splunk/Sumo
Jitter Beacon	Random variation added to interval to avoid pattern detection	57s, 63s, 59s, 61s, 58s — averages 60s but varies slightly	Statistical analysis: if average interval is consistent but individual times vary by $\pm 10-20\%$
HTTP/S C2	Uses legitimate web protocol to blend with normal traffic	POST to /update.php with encrypted/encoded body, specific User-Agent string	Analyze User-Agent (malware often uses fake or no User-Agent), POST frequency, Content-Length
DNS Tunneling	Encodes data in DNS query subdomain names to bypass firewalls	dGhpcyBpcyBhIHRlc3Q.evil.com DNS queries (data in subdomain)	DNS query length >50 chars, high frequency to single domain, low TTL, unusual subdomain entropy
Domain Generation Algorithm (DGA)	Malware auto-generates thousands of domain names — only one is active	Misspelled/random-looking domains: xk3p9qz.net, ah2ndk.xyz	High volume of NXDOMAIN responses, random-looking domain names, no legit WHOIS info

3.5 Writing YARA Rules

YARA is a pattern-matching tool widely used in security for malware detection. A YARA rule defines specific patterns (strings, byte sequences, PE import combinations) that identify a malware family. When you analyze a sample and find unique characteristics, you capture those in a YARA rule and deploy it across your environment to detect the same malware everywhere.

YARA Rule Structure

```
rule RuleName {
  meta:
    // Descriptive information — not used for detection
    description = "What this rule detects"
    author    = "Your Name"
    date      = "2025-01-01"
    severity  = "critical"

  strings:
    // What patterns to look for
```



```
$string1 = "plain text string" ascii
$string2 = "case insensitive" nocase
$string3 = { 4D 5A 90 00 } // hex bytes
$string4 = /regex[0-9]+/ // regular expression

condition:
// When to trigger the rule
2 of them // match if ANY 2 strings are found
// all of them // match only if ALL strings are found
// $string1 and ($string2 or $string3) // logical combinations
}
```

Real YARA Rule from This Scenario

```
rule Detect_FinanceRAT_svchost32 {
meta:
description = "Detects svchost32 RAT used in WS-FINANCE-01 incident"
author = "DFIR Team — CyArt"
date = "2025-01-01"
hash = "<SHA256 of sample — fill in after analysis>"
severity = "critical"
mitre_att = "T1547.001, T1071, T1055"

strings:
$c2_ip = "203.0.113.88" ascii
$mutex = "FinRat_Mutex" ascii nocase // from FLOSS output
$reg_key = "svchost32" ascii
$user_ag = "Mozilla/4.0 (compatible)" ascii // fake user agent from ANY.RUN

condition:
2 of them // triggers if any 2 of the above are found
}
```

YARA String Type	Syntax	Best Used For
Plain text (ASCII)	<code>\$s = "plain text" ascii</code>	C2 URLs, mutex names, registry paths, user agent strings
Case-insensitive	<code>\$s = "SvCHoSt" nocase</code>	Process names, strings that may vary in case
Wide (Unicode)	<code>\$s = "hello" wide</code>	Strings in 16-bit Unicode format (common in Windows strings)
Hex bytes	<code>\$s = { 4D 5A 90 00 03 }</code>	Specific byte sequences, malware signatures, shellcode stubs
Regular expression	<code>\$s = /http:\V\[[0-9.]+\:[0-9]+\/</code>	IP-based C2 URLs, domain patterns, encoded strings
Combined (ascii + wide)	<code>\$s = "string" ascii wide</code>	Catches both ASCII and Unicode versions of the same string

How to Test Your YARA Rule

```
# Test against a single file
yara64.exe -r detect_finance_rat.yar svchost32.exe

# Scan entire directory recursively
yara64.exe -r detect_finance_rat.yar C:\malware_samples\

# Scan all running processes in memory
yara64.exe -p detect_finance_rat.yar --pid=ALL
```

3.6 MITRE ATT&CK Framework — Mapping Malware Behaviour

The MITRE ATT&CK Framework is a globally recognized knowledge base of adversary tactics, techniques, and procedures (TTPs). Every technique has a unique ID. Mapping your malware analysis findings to ATT&CK creates a standardized, universally understood description of what the attacker did.

Tactic (Goal)	Technique ID	Technique Name	Applied to Our Scenario
Initial Access	T1566.001	Spear phishing Attachment	Malicious Word document sent by email
Execution	T1204.002	Malicious File — User Execution	User opened the Word file and enabled macros
Execution	T1059.003	Windows Command Shell	Macro launched cmd.exe to install malware
Persistence	T1547.001	Registry Run Keys	svchost32.exe added to HKLM\...\Run
Défense Evasion	T1055	Process Injection	Malware injected shellcode into its own process space
Défense Evasion	T1036.004	Masquerading — Name	svchost32.exe mimics legitimate svchost.exe
Command & Control	T1071.001	Web Protocols	HTTP POST used for C2 communication
Command & Control	T1071	Non-Standard Port	TCP:4444 used for raw C2 beacon
Exfiltration	T1048	Exfiltration Over Alternative Protocol	38MB sent via HTTP POST to C2 server
Impact	T1560	Archive Collected Data	patient_records.zip created for staging
Defense Evasion	T1070.001	Clear Windows Event Logs	Security log cleared (Event ID 1102)

3.7 Study Resources for Topic 3

Resource	URL	What You Will Learn
MalwareBazaar	https://bazaar.abuse.ch/browse	Real malware samples for practice triage analysis
ANY.RUN	https://any.run	Interactive sandbox for malware dynamic analysis
MITRE ATT&CK T1071	https://attack.mitre.org/techniques/T1071	Deep dive into C2 communication techniques
YARA Rules Documentation	https://yara.readthedocs.io/en/stable/writingrules.html	Official guide to writing effective YARA detection rules

Topic 4: Incident Response Lifecycle (NIST SP 800-61)

4.1 What is NIST SP 800-61?

NIST Special Publication 800-61 (Computer Security Incident Handling Guide) is the definitive US government standard for cybersecurity incident response. Published by the National Institute of Standards and Technology, it defines a structured 6-phase lifecycle that any organization can follow to handle incidents professionally, consistently, and effectively.

KEY POINT

Why follow NIST 800-61? Because ad-hoc incident response (just 'wing it') leads to missed evidence, extended attacker dwell time, regulatory non-compliance, and repeated incidents. A structured process ensures nothing is missed and provides legal and audit defensibility.

4.2 Phase 1 — Preparation (Before Any Incident)

Preparation is the most important phase because it determines how effectively you handle incidents when they occur. Organizations that invest in preparation detect attacks 10x faster and contain them with far less damage than unprepared organizations.

Preparation Item	What it Involves	Without This...
Incident Response Plan	Written document defining roles, responsibilities, severity levels, communication procedures, and step-by-step playbooks for each incident type	Analysts do not know who to call, what to do first, or how to escalate — critical time is wasted
Communication Tree	Who contacts whom, in what order, within what timeframe for each severity level	During a P1 incident, valuable minutes are wasted figuring out who to call
Jump Bag / IR Toolkit	Pre-configured laptop and USB drives with all forensic tools installed, tested, and ready to go immediately	Analyst arrives at incident and spends an hour installing tools instead of collecting evidence
Detection Rules (SIEM)	Wazuh/Elastic rules tuned to detect real attacker behaviors: unusual outbound ports, process injection, log clearing, etc.	Like our scenario: no rule for port 4444 = 7-hour detection gap
Tabletop Exercises	Quarterly 2-hour practice scenarios: Pretend you just got a ransomware alert — walk through the response as a team	First time team coordinates is during a REAL incident — costly mistakes happen
Access & Authorization	Analyst accounts have pre-approved access to all systems needed for investigation (SIEM, EDR, AD, firewall)	Analyst finds critical evidence but cannot access the system to collect it — evidence may be lost
Legal & Compliance Prep	Pre-approval for forensic imaging, pre-defined data handling procedures, legal counsel on retainer for data breach notification	Security team collects evidence improperly — it is inadmissible or triggers GDPR/HIPAA violations

4.3 Phase 2 — Detection & Analysis

Detection is when you first learn something may be wrong. Analysis is when you confirm what it is and determine its scope. These two activities happen simultaneously and continuously.

Alert Validation — Is This Real?

Not every alert is a real incident. The first task is to determine: true positive (real threat) or false positive (normal behavior that triggered an alert by mistake).

Question to Ask	Source to Check	Our Scenario Answer
Is the source IP/hostname legitimate?	CMDB, asset inventory, AD	Yes — WS-FINANCE-01 is a real finance workstation
Is the destination IP/domain malicious?	VirusTotal, AlienVault OTX, Threat Intel	Yes — 203.0.113.88 confirmed malicious on VirusTotal
Is this normal behavior for this system?	Historical SIEM data, user profile	NO — finance workstations do not beacon to external IPs on port 4444
Are there other alerts from this host?	SIEM — search all alerts for the same source	Check for related alerts: process creation, file modification, etc.
Has this IP appeared anywhere else?	SIEM — search all agents for same dst IP	Scope check: is it only one endpoint or multiple?

Severity Classification — How Bad Is It?

Severity Level	Definition	Example	Expected Response Time
P1 — Critical	Business operations stopped or at immediate risk; confirmed data breach in progress	Active ransomware spreading across network; confirmed C2 + exfiltration like our scenario	Response begins within 15 minutes. All senior staff engaged.
P2 — High	Significant impact to systems; strong indicators of compromise; no confirmed breach yet	Malware found on isolated endpoint; phishing campaign targeting multiple users	Response begins within 1 hour. IR team engaged.
P3 — Medium	Limited impact; possible compromise; needs investigation	Suspicious file found on workstation; single phishing attempt with no click	Response begins within 4 hours. Analyst investigates.
P4 — Low	Minimal impact; likely false positive or informational event	Port scan from external IP; failed login attempt	Investigated within 24 hours. Analyst reviews.

Scope Determination

Before containing, you must understand the scope: How many systems are affected? Is the attacker still active? What data is at risk? Rush to contain without scoping, and you may isolate one machine while the attacker is already on five others.

- Search SIEM for all hosts that communicated with the C2 IP in the past 30 days
- Search for the malware hash across all endpoints using EDR
- Review lateral movement indicators: new SMB connections, new RDP sessions, new user accounts created
- Check Active Directory for any changes: new accounts, privilege escalations, group membership changes

PRO TIP

Do NOT alert the attacker that you are investigating by immediately isolating the first machine you find. First, scope the full extent of the compromise. Then contain ALL affected systems simultaneously.

4.4 Phase 3 — Containment

Containment stops the bleeding. The goal is to prevent the incident from spreading further while preserving the environment for forensic investigation.

Containment Strategy	What it Means	When to Use	Trade-offs
Immediate Isolation	Physically or logically disconnect the affected system from all networks completely	When active data exfiltration is confirmed; when malware is spreading	Fast, effective, but alerts attacker. All volatile evidence must be collected FIRST.
Network Segmentation	Move affected systems to an isolated VLAN with no internet access but keep them running	When you need to continue collecting evidence; when legal hold is required	Slower but preserves evidence. Attacker cannot exfiltrate but may see suspicious network changes.
C2 Blocking	Block the C2 IP/domain at the firewall and DNS level for the entire network	Always — do this for every identified C2 indicator immediately	Fast, network-wide protection. But attacker may switch to backup C2.
Account Suspension	Disable all compromised user accounts and reset passwords	As soon as compromised credentials are identified	Prevents attacker from using stolen credentials. May disrupt legitimate users.
Deception (Honeytrap)	Leave infected system partially connected to monitor attacker behavior	When you need threat intelligence and legal/executive approval is obtained	Risky — attacker may cause more damage. Requires legal approval in many jurisdictions.

4.5 Phase 4 — Eradication

Once you fully understand what the attacker did and where they are, you systematically remove every trace of their presence. Do NOT rush to eradication before completing forensics — you may destroy evidence you still need.

- Remove ALL malware files: Use exact file paths from forensics. Do not guess.
- Delete ALL persistence mechanisms: Registry Run keys, Scheduled Tasks, malicious Services, startup folders
- Reset ALL compromised accounts: Every account the attacker touched must have a new password
- Revoke and reissue any potentially stolen API keys, certificates, or service credentials
- Patch the exploited vulnerability: Find the CVE number and apply the vendor patch
- Block ALL identified IOCs: Hash, IP, domain, URL, mutex — everywhere (firewall, proxy, DNS, EDR, SIEM)
- Remove attacker-created accounts: Check for new accounts created during the incident window

CRITICAL RULE

Do NOT eradicate before completing Phase 3 (forensics). You may permanently destroy evidence that is still needed to understand the full scope of the compromise.

4.6 Phase 5 — Recovery

Recovery restores affected systems to full, verified-clean operation. This is not just restoring from backup — it requires careful verification that the restored system is actually clean.

Recovery Step	How to Do It	Key Verification Check
Restore from clean backup	Use a backup from BEFORE the infection date (check your timeline). Restore to staging environment first.	Verify the backup date is before the first malicious event in your timeline
Rebuild from scratch	For heavily compromised systems, a fresh OS install from golden image is faster and more trustworthy than cleaning	Confirm all required applications reinstalled and tested before returning to production
Reimage the endpoint	Deploy standard OS image to the affected workstation	Verify the image is from an approved, uncompromised source
Validate clean state	Run AV scan with latest signatures, EDR behavioral scan, check for C2 connections	Zero C2 connections in SIEM for 72 hours after restoration
Monitor intensively	Increase logging verbosity, add specific detections for this attacker's TTPs, daily review	No re-infection alerts within 30 days
Staged return to production	Restore to production only after successful validation in staging	Business users sign off that operations are normal

PRO TIP

Keep the affected endpoint in forensic hold for at least 30 days after recovery. You may need to re-examine it if new information about the scope of compromise emerges.

4.7 Phase 6 — Post-Incident Activity

Phase 6 is the most important phase for PREVENTING the next incident. It is also the phase most often skipped. Professional IR teams treat the post-incident review as mandatory not optional.

- Lessons Learned Meeting: Hold within 2 weeks while memory is fresh. Include IR team, affected business unit, CISO, IT.
- Root Cause Analysis: Use 5 Whys (Topic 5) to find the REAL root cause — not just 'user clicked link'
- Metric Review: Calculate MTTD, MTTR, Dwell Time. Compare to targets. Identify gaps.
- Detection Improvement: Add new SIEM rules based on the attacker's TTPs. What would have caught this earlier?
- Playbook Update: Update your IR playbooks based on what worked and what didn't during this incident

- Training: If phishing was the initial vector, mandatory phishing awareness training for all affected departments
- Communication: Notify affected parties per regulatory requirements (HIPAA, GDPR — typically 72 hours for GDPR)

4.8 Study Resources for Topic 4

Resource	URL	What You Will Learn
NIST SP 800-61 Rev 2	https://nvlpubs.nist.gov/nistpubs/SpecialPublications/NIST.SP.800-61r2.pdf	The complete official incident response framework — read Sections 2-3
SANS Incident Handler's Handbook	https://www.sans.org/white-papers/incident-handlers-handbook	Practical hands-on guide to every phase of incident response
CISA IR Playbooks	https://www.cisa.gov/resources-tools/resources/federal-government-cybersecurity-incident-and-vulnerability-response-playbooks	Government-level playbooks for ransomware, data breach, and other incident types

Topic 5: Post-Incident Analysis & Executive Reporting

5.1 Why Post-Incident Analysis Matters

The incident is over. The attacker is gone, systems are restored, business is running. Most teams breathe a sigh of relief and move on. This is a critical mistake.

Post-incident analysis is where you extract the maximum learning value from an expensive and painful event. Every incident is a free lesson in what your specific attacker did, what your specific defenses failed to stop, and what your specific team struggled to do. Failing to analyze this is like paying tuition and skipping class.

KEY POINT

The goal of post-incident analysis is not blame — it is improvement. The question is never 'who made a mistake?' but always 'what process or technology failed, and how do we fix it?'

5.2 Root Cause Analysis — The 5 Whys Method

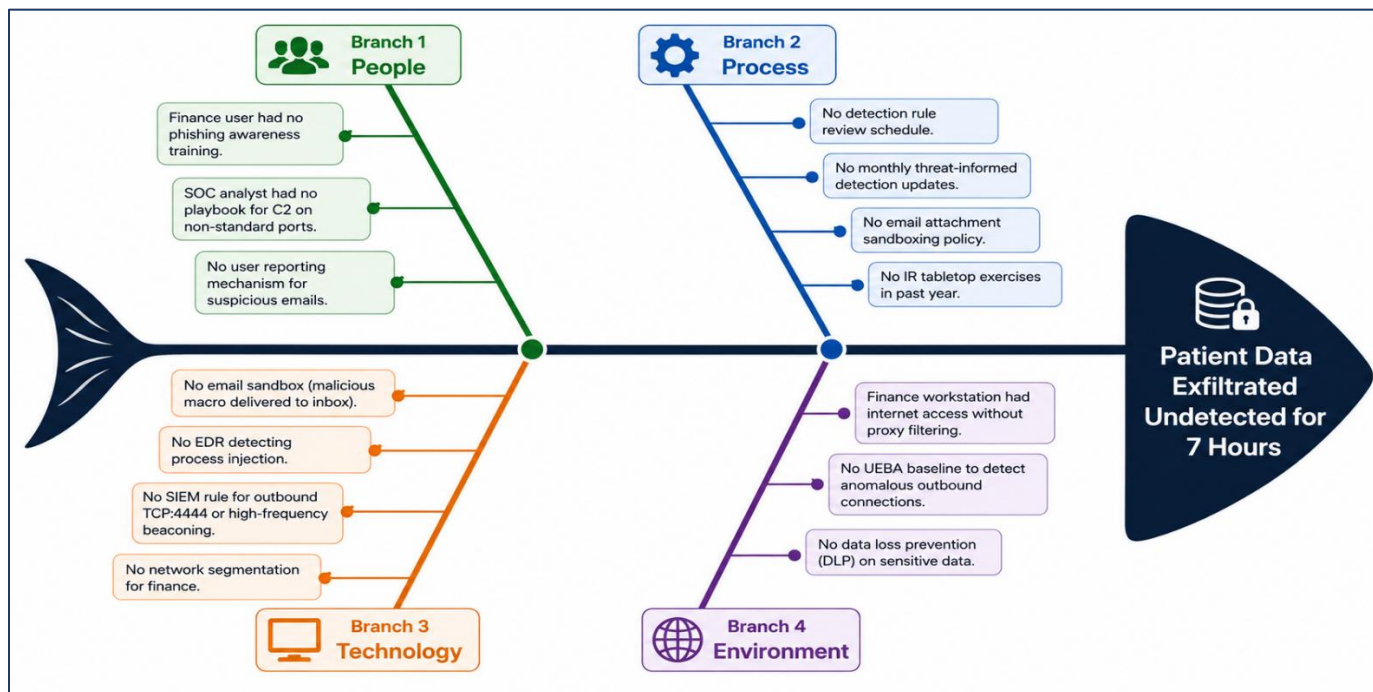
The 5 Whys is a structured technique developed by Toyota for manufacturing quality control. It is extremely effective in cybersecurity because it forces you to keep asking 'WHY' until you reach the SYSTEMIC root cause rather than stopping at a symptom.

Why #	Question	Symptom-Level Answer (WRONG)	Root Cause Answer (CORRECT)
Why 1	Why was patient data exfiltrated?	Because the attacker stole it	Attacker had 7+ hours of undetected access
Why 2	Why was the attacker undetected for 7 hours?	Because we did not detect the C2 traffic	No Wazuh rule existed for C2 on port 4444
Why 3	Why was there no detection rule for port 4444?	Because nobody created one	Detection rules had not been reviewed in 6 months
Why 4	Why were detection rules not reviewed in 6 months?	Because nobody did it	No scheduled detection engineering review process
Why 5 (ROOT CAUSE)	Why is there no detection review process?	STOP — this is systemic	No formal SOC maturity or improvement framework was ever adopted

CRITICAL RULE

Common mistake: Stopping at Why 1 or 2. 'The user clicked a phishing link' is NOT a root cause — it is a symptom. The root causes are WHY they were able to click it (no sandbox), WHY the email arrived in their inbox (no filtering), and WHY they were not trained to recognize it (no awareness program).

5.3 Fishbone Diagram



5.4 SOC Performance Metrics

Metrics quantify your SOC's performance. They turn abstract concepts like 'we detected it slowly' into concrete, measurable, comparable numbers that leadership and the team can act on.

Metric	Full Name	Definition	Formula	Target	Our Result
MTTD	Mean Time to Detect	Average time from the first malicious event to the SOC generating an alert	Time of SOC alert - Time of first malicious event	< 1 hour	7 hours 10 min — CRITICAL
MTTR	Mean Time to Respond	Average time from detection to full containment/mitigation	Time of containment - Time of SOC detection	< 30 minutes	1 hour 20 min — POOR
Dwell Time	Attacker Dwell Time	Total time the attacker was present in the environment undetected	Time of eradication - Time of initial access	< 1 hour	7 hours 50 min — CRITICAL
FPR	False Positive Rate	Percentage of alerts that are not real threats	$(\text{False alerts} / \text{Total alerts}) \times 100$	< 5%	Measure from your SIEM data
MTTI	Mean Time to Investigate	Time from alert to triage completion and decision point	Time of containment decision - Time of alert	< 1 hour	Measure from case timeline

KEY POINT

A high dwell time (attacker present for hours or days before detection) is the most dangerous metric gap. Every additional hour of dwell time means more systems compromised, more data stolen, and more cleanup required.

5.5 Lessons Learned Structure

A structured lessons learned process ensures you extract maximum value from every incident. Run this as a meeting within 2 weeks of incident closure.

Lessons Learned Section	Questions to Answer	Documentation Output
What Happened (Timeline)	Can everyone agree on the factual sequence of events?	Final approved attack timeline — the authoritative record
What Worked	Which tools, processes, or people performed well? What should we keep/expand?	List of strengths to reinforce and invest in
What Did Not Work	Where did tools fail? Where did processes break down? What slowed us down?	Honest gap list — this is where improvement comes from
Near Misses	What almost went wrong but was caught in time? What lucky factors helped?	Risks to address before luck runs out
Improvement Actions	Specific, actionable items with owners and deadlines	Action register: WHAT, WHO owns it, BY WHEN — tracked to completion
Metrics Review	Did MTTD, MTTR, dwell time meet targets? Why or why not?	Updated SOC scorecard — trend over time shows if team is improving

5.6 Executive Reporting — Translating Tech to Business

An executive report serves a completely different audience from a technical forensics report. The CEO, Board, or CFO does not know what PID 3821 or MTTD means. They do understand: cost, risk, regulatory exposure, competitive impact, and what they need to invest in.

Technical Language	Executive Language Translation	Why the Translation Matters
svchost32.exe (PID 3821) injected shellcode via T1055 process injection	Malicious software disguised itself as a standard Windows system program and secretly took full control of the computer	Executives understand 'took full control' — they do not need to know what process injection is
MTTD: 7 hours due to missing Wazuh detection rule for TCP:4444 outbound	Our security monitoring tools took 7 hours to detect the breach — our target is 1 hour. A gap in our monitoring rules caused the delay.	'7 hours vs 1 hour target' communicates the problem immediately without jargon
T1048 exfiltration: 38MB HTTP POST to 203.0.113.88	38 megabytes of patient data was sent from our network to a server controlled by the attacker	The word 'patient data' and 'attacker's server' communicates business risk clearly
Event ID 1102 — Security audit log cleared (T1070.001)	After stealing the data, the attacker deleted security records to make investigation harder — this is standard criminal evidence-destruction behavior	Comparing to familiar criminal behavior (evidence destruction) makes it relatable
No email sandboxing — macro executed via T1204.002	The malicious file was delivered directly to the employee's email inbox because we do not have email screening technology that tests attachments for malware before delivery	'We do not have X' is a clear investment signal for leadership

Executive Report Structure — What to Include

Section	Content	Length	Key Message
Executive Summary	What happened, current status (contained/not?), confirmed impact in 1-2 sentences	2-3 paragraphs	'Are we safe now?' — answer this immediately
Incident Timeline	Simple table: date/time → what happened. No technical jargon. Use business language.	1 page max	Shows the attack progressed over time and when it was detected
Business Impact	What data was at risk/confirmed stolen, which systems were affected, regulatory implications (HIPAA, GDPR, PCI)	1-2 paragraphs	'What is our legal and financial exposure?'
Actions Taken	What has been done: specific systems cleaned, accounts reset, monitoring enhanced	Bullet list	'Are you handling it?' — executives need reassurance of competent response
Root Cause	Why this happened — process/technology gap. NOT 'user error.'	1 short paragraph	'How do we stop it from happening again?'
Investment Required	Prioritized list of security improvements with estimated costs and ROI	3-5 bullet points	'What do you need from us?' — the ask for budget/resources

Sample Executive Summary Template

EXECUTIVE SUMMARY TEMPLATE

On [DATE], our security team identified and responded to a targeted cyber attack against our Finance department. A malicious file was delivered via email, resulting in the installation of unauthorized software on one Finance workstation. This software secretly communicated with an attacker's server for [HOURS] before detection. Analysis has confirmed that approximately [SIZE] of [DATA TYPE] was transmitted outside our network. The affected system has been isolated and cleaned, all attacker access has been blocked, and we have confirmed no other systems were compromised. We are assessing notification obligations under applicable regulations. A full review of security controls is underway, and we will present a prioritized investment roadmap at the next executive meeting.

5.7 Identified Gaps & Recommendations Framework

Recommendations must be specific and actionable — not vague ('improve security'). Each recommendation should include: WHAT the gap is, WHAT the specific fix is, WHO owns it, WHEN it will be done, and WHY it is prioritized that way.

Gap	Root Cause	Recommendation	Priority	Owner	Timeline
No SIEM rule for port 4444 C2 traffic	Detection rules not reviewed in 6 months	Add Wazuh rule: outbound TCP to non-standard ports from workstations to external IPs = immediate alert	P1	SOC Lead	48 hours
No email sandboxing	Never implemented	Deploy Microsoft Defender for Office 365 or Proofpoint to sandbox all attachments before delivery	P1	IT Security	1 week

No EDR with behavioral detection	Budget not approved previously	Deploy CrowdStrike Falcon or Microsoft Defender for Endpoint to all workstations	P1	CISO (budget)	30-60 days
No detection engineering review process	No process owner assigned	Monthly detection review: add new rules, retire false-positive rules, measure alert quality	P2	SOC Manager	30 days
No phishing awareness training	Low priority previously	Mandatory quarterly simulation and training — Finance team first	P2	Security Awareness Lead	60 days

5.8 Study Resources for Topic 5

Resource	URL	What You Will Learn
NIST SP 800-61 Section 3.4	https://nvlpubs.nist.gov/nistpubs/SpecialPublications/NIST.SP.800-61r2.pdf	The official post-incident activity guidance
SANS Reading Room	https://www.sans.org/reading-room	Post-incident review templates and best practices from practitioners
SANS Incident Response Resources	https://www.sans.org/white-papers/incident-handlers-handbook	Executive reporting templates and metrics frameworks

Quick Reference: Key Tools Summary

Tool	Category	Purpose	Where Used	Free?
Velociraptor	Live Forensics	Remote live endpoint queries (processes, network, artifacts)	Phase 2 — Evidence Collection	Yes
WinPmem	Memory Capture	Capture full RAM dump from live Windows system	Phase 2 — Evidence Collection	Yes
FTK Imager	Disk Imaging	Create forensic bit-for-bit disk images (.E01 format)	Phase 2 — Evidence Collection	Yes
Autopsy	Disk Analysis	GUI forensic tool — file carving, keyword search, deleted file recovery	Phase 3 — Disk Forensics	Yes
RegRipper	Registry Analysis	Extract and analyze Windows registry hive files	Phase 3 — Disk Forensics	Yes
Volatility 3	Memory Analysis	Analyze memory dumps — processes, network, injections	Phase 4 — Memory Forensics	Yes
Wireshark	Network Analysis	Capture and analyze network packets — beacons, exfiltration	Phase 5 — Network Analysis	Yes
PEStudio	Static Malware	Analyze PE executable files without running them	Phase 6 — Malware Analysis	Yes
FLOSS	Static Malware	Extract obfuscated strings from malware binaries	Phase 6 — Malware Analysis	Yes
ANY.RUN	Dynamic Malware	Interactive sandbox — run malware and watch behavior	Phase 6 — Malware Analysis	Free tier
VirusTotal	Threat Intel	Check file hashes and IPs against 70+ AV engines	Phases 1 & 6	Free
AlienVault OTX	Threat Intel	Community threat intelligence — IP/domain reputation	Phase 1	Free
TheHive	Case Management	Document and manage the incident investigation	All Phases	Yes
CrowdSec	Blocking	Block malicious IPs across all network segments	Phase 7 — Containment	Yes
Draw.io	Documentation	Create kill-chain and fishbone diagrams	Phases 8 & 9	Free
YARA	Detection	Create and run pattern-matching detection rules	Phase 6	Yes

Quick Reference: MITRE ATT&CK Techniques in This Scenario

Technique ID	Name	Stage	How Detected
T1566.001	Spearphishing Attachment	Initial Access	Email gateway logs, user report
T1204.002	User Execution — Malicious File	Execution	Process creation event (Word macro)
T1059.003	Windows Command Shell	Execution	cmd.exe spawned by winword.exe (pstree)
T1547.001	Registry Run Keys	Persistence	RegRipper on SOFTWARE hive; Autopsy

T1055	Process Injection	Defense Evasion	Volatility malfind (RWX region + MZ header)
T1036.004	Masquerading	Defense Evasion	svchost32.exe vs svchost.exe — pslist
T1071	Application Layer Protocol	C2	Wireshark — TCP:4444 beacon every 60 seconds
T1048	Exfiltration Over Alt Protocol	Exfiltration	Wireshark — 38MB HTTP POST to C2
T1560	Archive Collected Data	Collection	Autopsy — patient_records.zip (deleted)
T1052	Exfiltration Over Physical Medium	Exfiltration	USBSTOR registry key — USB connected
T1070.001	Clear Windows Event Logs	Defense Evasion	Event ID 1102 in Security.evtx

Quick Reference: RFC 3227 Evidence Priority Order

Priority	Evidence Type	Tool	Key Command
1 (Most Urgent)	Active network connections	Velociraptor / netstat	SELECT * FROM process_open_sockets
2	Running processes	Velociraptor / pslist	SELECT pid, name, path, cmdline FROM processes
3	Logged-on users	Velociraptor / query	SELECT * FROM logged_in_users
4	Memory (RAM dump)	WinPmem	winpmem_mini_x64.exe memory_dump.raw
5	Network traffic capture	Wireshark	Capture on span port — filter: ip.addr == [target]
6	Forensic disk image	FTK Imager	File > Create Disk Image > E01 format
7 (Least Urgent)	Event logs / SIEM data	Wazuh / export	Export all logs for affected host